IS01 — Information Security Policy

[Company] IIoT Platform

Project name: [Company] Security Policies	Status: Active
Date: [Date]	Version: 1.0
Author: [Author Name]	Reviewer: [Reviewer Name]

Versions

Revision	Date	Author	Description
1.0	[Date]	[Author Name]	Initial release

Related Standards, Policies and Processes

1) [Parent Company] IT – Corporate Information Security Policy

2) BS ISO/IEC 27001:2022 "Information security, cybersecurity and privacy protection - Information management systems - Requirements" + Annexes, ISO

3) BS ISO/IEC 27000:2020 "Information technology - Security techniques -Information security management systems - Overview and vocabulary", ISO

Definitions and Terms

Definitions and terms are taken mainly from BS ISO/IEC 27000:2020 and related standards and policies.

Overview

This document describes the policy and commitments that provide information security for the data and assets of the [Company] IIoT Platform.

Purpose

The purpose of this policy is to set out the information security policies that apply to the [Company] IIoT Platform, operated by [Company] as part of the [Parent Company] organization, to protect the confidentiality, integrity and availability of the data stored and processed by [Company] assets.

Scope

All employees, developers, contractors, customers and third-party users of the [Company] platform.

Statement of Commitment

We are fully committed to the continuous improvement of our Information Security Management System (ISMS). We recognize that information security is integral to our business operations and we are dedicated to protecting our IT systems and information assets.

We are accountable for the effectiveness of our ISMS and we ensure that our security policies and objectives are established, compatible with the strategic direction of our organization, and integrated into our business processes. We promote the use of a process approach and risk-based thinking in managing our information security.

We are committed to providing adequate resources and support to achieve the intended results of our ISMS. We engage, direct, and support all members of our team to contribute to the effectiveness of our ISMS.

We understand that without active leadership involvement, our ISMS will not be effective. Therefore, we participate in management reviews and demonstrate our commitment during audits. We believe that information security management is a business-critical philosophy and must be compatible with our business objectives and processes.

We are committed to continually improving our ISMS and we invest in a robust information security management system that evidences our commitment. We are involved in management reviews, decision-making processes related to information security, and we comply with the required annual external audits to validate our current posture.

[Company] IIoT Platform Management

Policy

Introduction

The [Company] platform processes data belonging to its customers and employees. Customer data collected, processed or derived by [Company] is owned by the customer regardless of its type, and [Company] treats it as private. Personal data of [Company] employees is treated as confidential and protected in line with applicable privacy law.

Information security protects the information that is entrusted to us. Getting information security wrong can have significant adverse impacts on our employees, our customers, our reputation and, by extension, our finances. With an effective information security management system, we can:

- provide assurance for our legal, regulatory and contractual obligations
- ensure the right people have the right access to the right data at the right time
- provide protection of personal data as defined in regional laws (CCPA, GDPR, etc.)

- be a good data citizen and custodian

Information Security Objectives

1. To ensure the confidentiality, integrity and availability of organization information including all personal data as defined by laws and regulations such as CCPA and GDPR, based on good risk management, legal, regulatory and contractual obligations, and business needs.

2. To provide the resources required to develop, implement and continually improve the Information Security Management System.

3. To effectively manage third-party suppliers who process, store or transmit information, or who provide components or assets that do so, in order to reduce and manage information security risks.

4. To implement a culture and good practices of information security and data protection through effective training and awareness.

Information Security Definition

Information security is defined as preserving:

- **CONFIDENTIALITY – access to information only for those with appropriate authority.**
- **INTEGRITY – the completeness and accuracy of information.**
- **AVAILABILITY – information is available and accessible when it is needed.**

In general, information security ensures that the right entities have the right access to the right data at the right time.

Information Security Policy Framework

The information security management system is built upon an information security policy framework. In conjunction with this policy, the following policies make up the policy framework:

1. DP01 - Data Protection and Retention Policy

2. IS01 - Information Security Policy (this)

3. IS02 - Access Control Policy

4. IS03 - Asset Management Policy

5. IS04 - Information Security Awareness and Training Policy

6. IS05 - Backup Policy

7. IS06 - Third-Party Supplier Security Policy

8. IS07 - Logging and Monitoring Policy

9. IS08 - Secure Development Policy

10. IS09 - Vulnerability Management Policy

11. IS10 - Cloud Service Security Policy

Information Security Roles and Responsibilities

Information security is the responsibility of everyone: to understand and adhere to the policies, follow processes, and report suspected or actual breaches or violations. Specific roles and responsibilities for the running of the Information security management system are defined and recorded in Appendix A to this policy – Information Security Roles and Responsibilities.

Monitoring

Compliance with the policies and procedures of the information security management system is monitored by the [Company] Management Review Team, together with periodic independent reviews by both internal and external audit.

Legal and Regulatory Obligations

The organization takes its legal and regulatory obligations seriously, and these requirements are recorded in Appendix B – Legal and Contractual Requirements Register.

Training and awareness

Policies are made readily and easily available to all employees and third-party users. A training and communication plan is in place to communicate the policies, processes and concepts of information security. Training needs are identified, and relevant training requirements are captured in Appendix C – Competency Matrix.

Continual Improvement of the Management System

The information security management system is continually improved and tuned based on customer and auditor feedback, as well as internal improvement initiatives. All changes are documented in accordance with the Change Management Policy.

Policy Compliance

Measurement

The [Company] Management Review Team will verify compliance with this policy through various methods, including but not limited to business tool reports, internal and external audits, and feedback to the policy owner.

KPIs for each topic-specific policy are defined in the ISMS KPI Registry standard.

Exceptions

Any exception to the policy must be approved and documented by the Information Security Specialist in advance and reported to [Company] Management Review Team.

Non-Compliance

An employee found to have violated this policy may be subject to disciplinary action up to and including termination of employment and further legal action.